

Vendor Risk Management Policy

Document ID: POL-VRM-005 Version: 4.0 Effective Date: 2025-08-01 Owner: Enterprise Risk Management

1. Purpose and Scope

This policy establishes the framework for assessing, monitoring, and mitigating risks associated with third-party vendors and suppliers across their full engagement lifecycle, from onboarding through offboarding. It applies to all vendors with access to Company systems, data, facilities, or that provide services material to Company operations.

2. Vendor Risk Tiers

Vendors are classified into one of four risk tiers at onboarding and reassessed annually or upon material change in scope:

Tier 1 — Critical

Vendors with access to Restricted data, core production systems, or whose failure would materially disrupt operations. Requires: - Annual on-site or virtual security audit - SOC 2 Type II report (or equivalent) on file, renewed annually - Business continuity plan review - Executive sponsor sign-off at onboarding and each renewal - Quarterly business review meetings

Tier 2 — High

Vendors with access to Confidential data or systems supporting important but non-core functions. Requires: - Security questionnaire completed annually - SOC 2 Type I or equivalent attestation - Semi-annual business review

Tier 3 — Moderate

Vendors with access to Internal data only, no direct system access. Requires: - Security questionnaire at onboarding, refreshed every 2 years - Standard contractual data protection clauses

Tier 4 — Low

Vendors with no access to Company data or systems (e.g., facilities, catering). Requires: - Standard procurement onboarding only; no additional risk assessment

3. Onboarding Requirements

Before a contract can be executed with a new vendor, Procurement must: 1. Determine the appropriate risk tier based on data/system access scope 2. Confirm the vendor has completed all tier-appropriate assessments 3. Verify insurance coverage meets minimum thresholds (see Section 6) 4. Confirm the contract includes all mandatory clauses per Procurement Policy POL-

PROC-001 and, where applicable, the data privacy clause required by Information Security Policy POL-SEC-002 5. Screen the vendor against sanctions and watch lists

Contracts executed without completing tier-appropriate onboarding steps are considered non-compliant regardless of contract value.

4. Ongoing Monitoring

- Tier 1 and Tier 2 vendors must be reassessed at least annually.
- Any security incident involving a vendor (breach, outage, data loss) must trigger an immediate off-cycle risk reassessment.
- Vendor risk scores must be reviewed by Enterprise Risk Management before any contract renewal or amendment increasing scope of data access.

5. Fourth-Party (Subcontractor) Risk

Vendors that use subcontractors to fulfill contracted services must disclose all subcontractors with access to Company data. The vendor remains fully liable for subcontractor compliance with this policy and the underlying contract’s data protection terms. Undisclosed subcontracting that involves data access is treated as a material breach.

6. Insurance Requirements

Minimum insurance coverage by tier:

Tier	General Liability	Cyber Liability	Professional Liability
Tier 1	\$2,000,000	\$5,000,000	\$2,000,000
Tier 2	\$1,000,000	\$2,000,000	\$1,000,000
Tier 3	\$500,000	\$1,000,000	Not required
Tier 4	\$500,000	Not required	Not required

Proof of insurance must be on file before contract execution and renewed annually; lapses must be flagged and may trigger contract suspension.

7. Offboarding

At contract termination or expiration, the vendor must: 1. Return or securely destroy all Company data within 30 days, with written certification of destruction for Tier 1 and Tier 2 vendors 2. Have all system access revoked within 24 hours of termination 3. Complete a final risk closure review documenting any outstanding issues

8. Exceptions

Any exception to this policy requires written approval from the Chief Risk Officer and must be time-bound with a defined remediation plan. Exceptions cannot be granted for Tier 1 vendors without additional Board Risk Committee notification.

9. Roles and Responsibilities

- **Procurement:** initial tier classification, onboarding checklist completion, contract clause verification
- **Enterprise Risk Management:** ongoing monitoring, annual reassessments, exception approvals below CRO threshold
- **Information Security:** security questionnaire review, breach response coordination, SOC 2 report evaluation
- **Legal:** contract clause sufficiency review for Tier 1 and Tier 2 vendors
- **Business Owner:** day-to-day vendor relationship management and escalation of performance or risk concerns

10. Related Documents

- Procurement Policy (POL-PROC-001)
- Information Security Policy (POL-SEC-002)
- Payment Policy (POL-PAY-003)
- SOP: Contract Approval Process (SOP-CA-010)